

REQUEST FOR PROPOSAL & STATEMENT OF WORK

E-Commerce Platform Development — RetailMax Corp

Client: RetailMax Corp | **Vendor:** TechBuild Solutions | **Budget:** \$850,000 | **Duration:** 12 months | **Start:** 2026-08-01

1. Project Overview & Goals

RetailMax Corp requires a cloud-native, multi-tenant e-commerce platform supporting 500,000 concurrent users, integrated with third-party logistics, payment gateways (Stripe, PayPal), and a personalisation recommendation engine. The platform must be PCI-DSS Level 1 compliant from day one.

Goals: (1) Launch MVP storefront within 4 months. (2) Achieve 99.95% uptime SLA. (3) Process 10,000 orders/hour at peak. (4) Full PCI-DSS Level 1 certification within 6 months.

2. Scope of Work & MVP

MVP (Month 1–4): Product catalog, user authentication, shopping cart, Stripe payment integration, order management, email notifications. MVP is considered complete when 100 end-to-end purchase transactions succeed in staging without errors and all P0 defects are resolved.

Full Scope: Recommendation engine, multi-vendor marketplace, returns management, analytics dashboard, loyalty programme, mobile PWA.

Out of Scope: Physical POS integration, cryptocurrency payments, custom ERP connectors not listed herein.

3. Work Breakdown & Timelines

ID	Work Item	Timeline	Entry Criteria	Definition of Done / Exit Criteria
WI-001	User Authentication & IAM	Sprint 1–2 (Wk 1–4)	Design approved; dev env ready	OAuth2/OIDC login, MFA enabled, OWASP auth checklist passed
WI-002	Product Catalog Service	Sprint 2–3 (Wk 3–6)	WI-001 done; DB schema approved	CRUD APIs functional, search latency <200ms p99, 10k products
WI-003	Shopping Cart & Checkout	Sprint 3–4 (Wk 5–8)	WI-002 done; Stripe sandbox ready	Cart persists across sessions, checkout completes <3s, PCI-DSS
WI-004	Order Management System	Sprint 4–5 (Wk 7–10)	WI-003 done	Order lifecycle (placed→shipped→delivered) automated, webhooks
WI-005	Recommendation Engine	Sprint 6–8 (Wk 11–16)	WI-002 done; ML infra provisioned	CTR uplift ≥5% vs baseline in A/B test, model serves <100ms
WI-006	Multi-Vendor Marketplace	Sprint 8–10 (Wk 15–20)	WI-004 done; vendor onboarding flow approved	Vendor onboarding <30 min, commission calculation accurate
WI-007	Analytics Dashboard	Sprint 10–11 (Wk 19–22)	WI-004 done; BI tool selected	Real-time sales KPIs refresh <5s, 6-month historical data loaded
WI-008	Performance & Load Testing	Sprint 11–12 (Wk 21–24)	All WIs done	Platform sustains 10,000 orders/hour; p99 latency <500ms; zero

4. Legal & Contractual Obligations

4.1 Late Delivery Penalty: Vendor shall pay a penalty of 1.5% of the milestone value per calendar week of delay, up to a maximum of 15% of total contract value. Delays beyond 10 weeks on any critical-path milestone grant Client the right to terminate the contract without further liability.

4.2 Subcontracting: Vendor may subcontract non-core activities (e.g., QA, DevOps) with prior written consent from Client. Core development and architecture roles may not be subcontracted. All subcontractors must sign the Client's NDA and security policy.

4.3 Indemnity: Vendor shall indemnify and hold harmless Client against any third-party claims arising from Vendor's breach of this SoW, including IP infringement, data breaches attributable to Vendor's code, and gross negligence. Client indemnifies Vendor against claims arising from Client-provided data.

4.4 Intellectual Property: All deliverables, source code, documentation, and models produced under this SoW are works-for-hire and vest exclusively in Client upon payment. Vendor retains no licence to reuse deliverables for competing projects.

4.5 Insurance: Vendor must maintain: Professional Indemnity $\geq$ \$2M per occurrence; Cyber Liability $\geq$ \$5M per occurrence; General Liability $\geq$ \$1M. Certificates of insurance to be provided within 14 days of contract signing.

5. Security Requirements

5.1 SAST: Static Application Security Testing must be integrated into the CI/CD pipeline. All code commits to main branch require a passing SAST scan (Snyk or Semgrep). Zero critical/high vulnerabilities may be present at any release gate.

5.2 VAPT: A full penetration test (web application + API layer) must be conducted by a CREST-certified third party prior to production go-live and annually thereafter. Vendor must remediate all critical findings within 14 days and high findings within 30 days.

5.3 PCI-DSS: Platform must achieve and maintain PCI-DSS Level 1 compliance. Quarterly ASV scans required. Cardholder data environment must be segmented and documented. QSA engagement is Vendor's responsibility and cost.

6. Project Closure

Project closure requires: (1) All WIs marked Done per Definition of Done. (2) Signed UAT acceptance from Client. (3) PCI-DSS Level 1 AOC delivered. (4) VAPT final report with all criticals/highs resolved. (5) Operations runbook and DR plan delivered. (6) Knowledge transfer sessions completed (minimum 3 sessions). (7) 30-day hypercare period with SLA $\geq$ 99.9% completed without P0 incidents.